

15 Feb 2020

01

US\$ 8M

bZx Protocol

"O primeiro flash loan attack da história"

FLASH LOAN + ORACLE • CRITICAL

0 que aconteceu

02

bZx era um protocolo de margin trading descentralizado. Usava **oráculos on-chain** (Kyber/Uniswap) para obter preços de ativos.

O atacante fez um **flash loan** de 10.000 ETH no dYdX — empréstimo sem colateral que precisa ser devolvido na mesma transação.

Com esse capital, **manipulou o preço** em uma pool de baixa liquidez e fez margin trading no bZx usando o preço inflado.

O bZx liquidou a posição com o **preço real**, mas o atacante já tinha lucrado a diferença. Tudo em **uma única transação atômica**.

● Contrato Vulnerável

03

INHA VULNERÁVEL

● ● ● SOLIDITY / VULNERABLE

```
st, srcQty ); // Preço manipulável com flash loan! //
Sem TWAP, sem múltiplas fontes }
```

Lição

Use oráculos descentralizados (Chainlink) com TWAP — nunca preço spot de uma pool única.

Como o ataque funcionou

PASSO 1

Flash loan: pega 10.000 ETH emprestado (dYdX)



PASSO 2

Deposita 5.000 ETH como colateral no Compound



PASSO 3

Swap 5.000 ETH em pool rasa → preço dispara



PASSO 4

bZx consulta oráculo → lê preço inflado



PASSO 5

Margin trade no bZx com preço manipulado



PASSO 6

Devolve flash loan + fica com US\$8M de lucro

Tudo em UMA transação • ~15 segundos

● Verifique na Blockchain

05

Transação do Ataque #1etherscan.io/tx/0xb5c8bd...19838Contrato bZxetherscan.io/address/0x493C57...9081

SMARTCONTRACT ENGINEER

Solidity

Lucas Bispo de Oliv

SMARTCONTRACT

Solidi

Solidity de f

